

New API 金融级 AI API 网关

专业完整解决方案

标准化统一接入层 · Gemini 官方直连 · 智能路由 · RPM/TPM 吞吐优化 · 全链路可观测 · 金融级安全治理

方案定位

本方案面向 new-api 项目的生产级与金融级改造，目标是在合规授权前提下，提供稳定中转、统一 API 入口、高可用路由、精细权限控制、可观测运维、账本化计费 and Gemini 官方直连吞吐优化能力。

版本：v1.0 生成日期：2026-06-01

适用对象：平台负责人、后端架构师、安全负责人、SRE、AI 应用研发团队、企业客户交付团队

文档控制

项目	内容
文档名称	New API 金融级 AI API 网关专业完整解决方案
版本	v1.0
范围	new-api 源码级改造、Gemini 官方直连、吞吐与 RPM 优化、金融级安全、可观测与生产运营
关键产出	目标架构、核心模块、数据模型、接口规范、开发计划、验收标准、运营清单
设计口径	不绕过上游服务条款；在合规授权、额度申请、项目池化、缓存、批处理、排队和限流策略内提升有效吞吐

目录

- 1. 执行摘要
- 2. 业务目标与产品定位
- 3. 当前源码诊断与金融级差距
- 4. 设计原则与标准参考
- 5. 目标总体架构
- 6. 标准化统一接入层设计
- 7. Gemini 官方直连与 RPM/吞吐优化设计
- 8. 高可用智能路由引擎
- 9. 金融级安全与合规治理
- 10. 鉴权与权限控制体系
- 11. 账本化计费、配额与对账
- 12. 全链路可观测平台
- 13. 数据模型与源码改造清单
- 14. 接口与 SDK 接入规范
- 15. 部署架构与运维方案
- 16. 分阶段开发路线图
- 17. 测试、验收与上线门禁
- 18. 风险清单与治理措施
- 19. 交付物清单
- 20. 参考资料

1. 执行摘要

new-api 已具备多模型网关、渠道池、Token 管理、计费预扣、管理后台和多协议 Relay 的基础能力。若要面向金融级和企业级生产场景，需要从“可用网关”升级为“可治理、可审计、可扩展、可对账、可容灾”的 AI API 平台。

核心结论

本方案建议采用“控制面 + 数据面 + 可观测面 + 审计账本面”的四面架构：

- 数据面承载统一 API、认证、限流、路由、Relay、降级和熔断；
- 控制面管理租户、凭证、策略、渠道、模型、价格和审批；
- 可观测面覆盖请求、额度、成本、错误、延迟、队列和渠道健康；
- 审计账本面负责不可篡改日志、账本化计费、对账和合规留痕。

目标能力	建设内容	业务价值
稳定中转	统一接入层、上游连接池、路由降级、熔断、重试预算	降低业务方对接复杂度，提升核心调用链稳定性
统一 API 入口	OpenAI-compatible、Gemini、Claude、Responses、Embedding、Batch 统一入口	业务侧只需维护统一 SDK、统一密钥和统一错误模型
高可用路由	QuotaCell、Project Pool、健康评分、SLA 感知调度	提升 Gemini 官方直连与多上游模型的可用性和吞吐利用率
权限与安全	mTLS/JWT/JWKS/HMAC、RBAC/ABAC、RoutePolicy、MFA、审批流	满足企业和金融级高价值接口访问控制要求
调用监控可观测	Trace、指标、日志、审计、额度水位、队列和成本看板	快速定位问题，持续优化容量、成本和 SLA
面向生产体验	一致调用方式、幂等、灰度、版本治理、回滚、灾备	从开发测试到线上发布保持稳定和可维护的接入结构

2. 业务目标与产品定位

目标产品不是“简单转发代理”，而是一个标准化 AI API 网关和 AI 资产管理平台。它将上游模型、额度、密钥、价格、路由策略、用户权限、调用日志和成本账本抽象成统一平台能力。

2.1 产品卖点

产品能力	设计说明	对客户的承诺
稳定中转	对上游 Gemini、OpenAI-compatible、Claude、私有模型做统一连接管理、重试、降级和熔断	减少上游 SDK、鉴权方式、错误码和限流差异带来的集成成本
统一 API 入口	以 OpenAI-compatible 为主接口，同时保留 Gemini 原生能力和 Batch/Realtime 能力	业务只对接一个域名、一套 Token、一组错误码、一套观测指标
高可用路由	请求进入后根据模型、租户、额度、延迟、健康度、成本、优先级进行调度	核心链路可以跨项目、跨模型、跨渠道自动切换
鉴权与权限控制	Token、租户、分组、模型、路由、IP、证书、scope、MFA 多维控制	避免越权调用、密钥泄露和高风险接口误操作
调用监控可观测	记录状态、时延、上游错误、429、队列等待、额度水位、成本和 trace	研发、SRE 和客户支持可快速定位问题
生产接入体验	提供 SDK、示例、灰度、幂等、错误码、回放、审计、对账	开发测试和线上发布保持一致调用方式

2.2 不做什么

- 不通过违规多账号、伪造身份、绕过官方限制等方式提升吞吐。
- 不在日志中默认记录用户完整 prompt、上游 key、Authorization、Cookie 或支付敏感字段。

- 不把缓存作为绕过模型安全策略或绕过用户授权边界的手段。
- 不允许管理后台公网裸奔，敏感接口必须具备更强认证、授权、审计和审批。

3. 当前源码诊断与金融级差距

基于前序对 new-api 源码的分析，当前项目已经有较完整的基础功能：Go + Gin + GORM 后

端、SQLite/MySQL/PostgreSQL/Redis 支持、双前端嵌入、TokenAuth、UserAuth、AdminAuth、渠道池、模型路由、预扣费、失败退款、日志、订阅、Midjourney/Suno 任务接口等。

源码区域	现有能力	金融级差距	改造建议
main.go	初始化环境、DB、Redis、缓存、后台任务、Gin 路由、session、HTTP server	安全启动门禁不足；中间件顺序缺少统一安全上下文和审计起点	新增 Financial Security Mode、SecurityContext、AuditStart、强制生产密钥检查
model/main.go	DB 选择、迁移、初始化 setup/root 逻辑	默认 root/123456 初始化路径高风险	改一次性 setup token；首次初始化强制改密并写审计
middleware/auth.go	TokenAuth、UserAuth、AdminAuth、IP 限制、分组校验	缺 mTLS/JWT/JWKS/HMAC、scope、MFA、RoutePolicy	新增 ClientCredential 与 PolicyEnforcer，保留 API key 兼容
middleware/distributor.go	模型解析、渠道选择、亲和性、模型限制	协议解析分支复杂；缺 QuotaCell 和 SLA 感知调度	抽象 ProtocolAdapter、Quota-Aware Router、Deadline-aware Scheduler
controller/relay.go	请求校验、token 估算、计费、重试、Relay、WebSocket	WebSocket Origin 放行；计费非账本化；流式断连处理需增强	增加 WS 白名单、ephemeral token、ledger billing、stream finalize
model/channel.go	Channel key 加密、模型映射、多 key、轮询/随机	缺 KMS/Vault、密钥版本、访问审计；多节点轮询一致性不足	Envelope Encryption、SecretMetadata、Redis 原子多 key 选择
router/api-router.go	用户、渠道、token、订阅、日志、模型等管理接口	管理接口面大；缺统一 API inventory 和敏感接口分级	RouteSecurityPolicy、APIEndpoint inventory、Step-up MFA、审批流

3.1 主要风险清单

风险	等级	说明	治理措施
默认初始化账号	高	固定 root/123456 一旦暴露会造成系统接管风险	删除固定密码，使用一次性 setup token + 强制 MFA
WebSocket Origin 全放行	高	浏览器环境可能导致跨站滥用和 token 盗用后的放大风险	Origin 白名单、ephemeral token、mTLS/HMAC 服务端认证
计费状态分散	高	预扣、退款、违规费若无账本和幂等，可能出现差错账	BillingLedger、幂等键、对账任务、断连 finalize
多节点额度一致性	高	RPM/TPM 限流和多 key 轮询若仅本地锁，会在横向扩展时失准	Redis Lua 原子桶、QuotaReservation、集中状态准
管理接口越权	高	Root/Admin 粗粒度不足以覆盖高价值操作	RBAC/ABAC、RoutePolicy、审批流、完整审计
上游 key 生命周期	中高	仅本地加密无法满足 KMS/Vault、轮换、访问审计要求	Envelope Encryption、密钥版本、轮换和审计
API 资产不可见	中高	未注册、废弃、调试接口可能被暴露	API inventory、schema validation、unknown endpoint block
观测粒度不足	中	只看请求日志不足以定位额度水位、队列、成本和渠道健康问题	全链路 metrics、trace、dashboard、SLO 告警

4. 设计原则与标准参考

4.1 设计原则

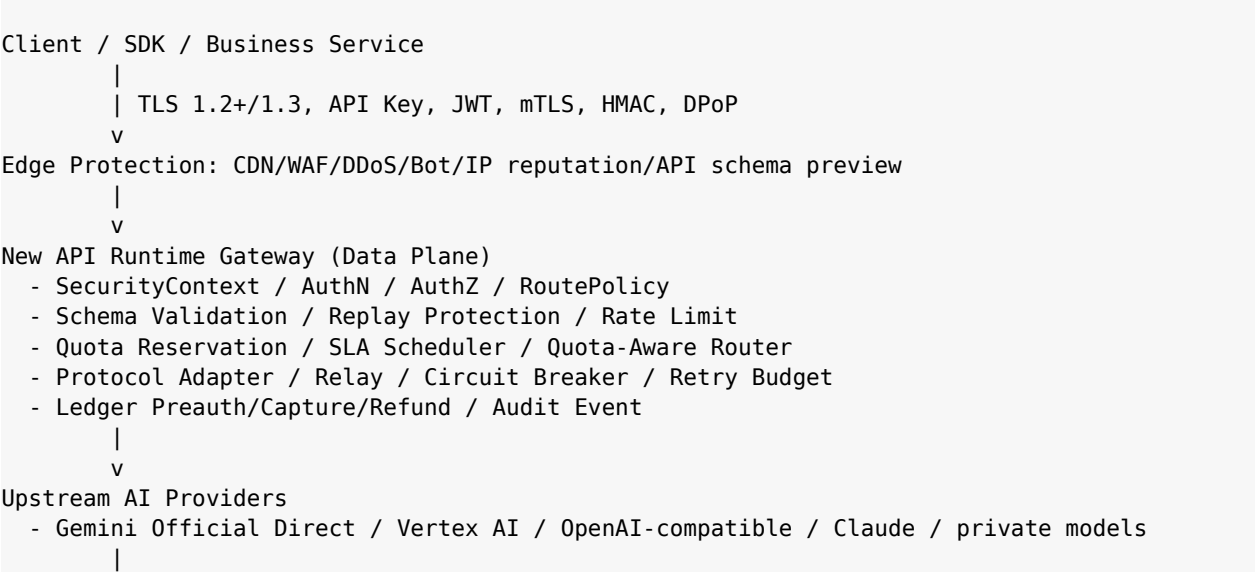
原则	设计要求
零信任	不基于网络位置给予隐式信任；每次访问都需要认证、授权、上下文评估和审计。
最小权限	Token、用户、客户端、路由、模型、分组、渠道均按最小可用范围授权。
安全左移	在进入 Relay 前完成鉴权、schema、限流、quota 预占和风险检查。
策略化	认证、授权、路由、限流、审批、审计和降级均通过策略配置驱动。
账本化	所有计费事件以 ledger 形式记录，余额只是账本结果，不是唯一事实源。
可观测	每个请求可从 trace_id 串联安全、路由、上游、计费和审计事件。
合规吞吐	通过额度申请、项目池化、批处理、缓存、排队和调度提升有效吞吐，不绕过官方限制。

4.2 标准与头部平台设计映射

参考方向	可借鉴能力	本方案落地
FAPI 2.0 / OAuth 高安全实践	TLS 1.2+、sender-constrained token、mTLS/DPoP、private_key_jwt、最小权限	ClientCredential、mTLS、DPoP/HMAC、JWT/JWKS、RoutePolicy
NIST Zero Trust	认证授权独立于网络位置，保护资源而非仅保护网段	SecurityContext、持续授权、RoutePolicy、设备/证书/IP 上下文
OWASP API Security Top 10	对象级授权、认证、资源消耗、函数级授权、资产清单、第三方 API 消费风险	API Inventory、ABAC、分层限流、schema validation、上游安全策略
Google Gemini 官方限制模型	RPM、TPM、RPD 按 project/model 等维度约束；Batch API 独立限流	QuotaCell、RPM/TPM 双桶、Project Pool、Batch Lane、额度水位面板
头部 API Gateway / APIM 思路	策略编排、配额、限流、WAF、mTLS、日志、灰度、版本治理	数据面 + 控制面 + 可观测面 + 审计账本面 四层架构

5. 目标总体架构

目标架构将 new-api 拆分为数据面、控制面、可观测面和审计账本面。数据面保持高性能、无状态；控制面负责策略和配置；可观测面负责指标、日志、trace 和告警；审计账本面保证合规留痕和计费准确性。



```

+----> Observability Plane: metrics, traces, logs, quota, cost, SLO
+----> Control Plane: tenants, credentials, policies, channels, pricing
+----> Audit & Ledger Plane: immutable audit, billing ledger, reconciliation

```

5.1 四面职责

平面	职责	关键模块
数据面	处理线上请求，保证低延迟、高可用和强控制	SecurityContext、AuthN/AuthZ、Quota、Router、Relay、CircuitBreaker
控制面	管理租户、凭证、策略、渠道、模型、价格、审批和灰度	Admin API、Policy Center、Credential Center、Channel Center、Model Catalog
可观测面	提供请求状态、错误、延迟、额度、队列、成本、SLO 和告警	Metrics、Tracing、Log、Dashboard、Alert、SLO Report
审计账本面	记录不可篡改审计、账本化计费和对账	AuditEvent、BillingLedger、Hash Chain、SIEM Sink、Reconciliation

6. 标准化统一接入层设计

标准化统一接入层的目标是让业务方只关心业务 prompt、模型能力和 SLA，不再直接关心上游 SDK、认证方式、错误码、限流策略和不同模型供应商接口差异。

6.1 统一入口能力

能力	实现方案
统一域名	生产建议使用 api.company.com 或 ai-gateway.company.com；内部服务通过 service mesh 或内网域名访问。
统一协议	优先提供 OpenAI-compatible 接口，同时保留 Gemini 原生、Batch、Realtime、Responses 等扩展接口。
统一密钥	业务侧使用平台 Token 或企业 ClientCredential；上游 key 只在网关侧管理。
统一错误码	将上游 401/403/429/5xx/timeout/model_not_found 统一映射成平台错误模型。
统一审计	每个请求绑定 request_id、trace_id、tenant_id、token_id、channel_id、ledger_id。
统一 SDK	提供 Node/Python/Go SDK 和 Curl 模板，支持自动重试、Retry-After、幂等键和 trace 注入。

6.2 推荐请求头规范

Header	是否必需	说明
Authorization: Bearer sk-xxx	是	普通 API key 鉴权，金融模式可要求 JWT/mTLS/HMAC 替代或叠加。
X-Tenant-ID	企业场景必需	租户 ID，用于配额、账单、审计和策略隔离。
X-Request-ID	建议	调用方生成的请求 ID；若缺失由网关生成。
Idempotency-Key	计费/任务接口必需	防止重放和重复扣费，尤其适用于任务和支付类接口。
X-SLA-Priority	建议	interactive、workflow、batch、background。
X-Execution-Mode	可选	auto、interactive、batch、sync、async。
X-Model-Policy	可选	allow_degrade、no_degrade、prefer_low_cost、prefer_low_latency。

6.3 统一错误模型

```
{
  "error": {
    "code": "quota_exhausted",
    "message": "Gemini project RPM quota is temporarily exhausted",
    "type": "rate_limit_error",
    "request_id": "req_...",
    "trace_id": "trace_...",
    "retry_after_ms": 3200,
    "retryable": true,
    "upstream": {
      "provider": "google-gemini",
      "model": "gemini-2.5-flash",
      "quota_cell": "project-prod-001:global:gemini-2.5-flash"
    }
  }
}
```

7. Gemini 官方直连与 RPM/吞吐优化设计

合规口径

“突破 RPM 上限”不等于绕过上游限制。正确设计是：在官方授权、项目额度、计费 tier、Batch API、缓存、排队、限流和观测的框架内提升有效吞吐，并通过本地准入控制避免把流量打爆到上游。

7.1 限流事实模型

Gemini API 的限流通常至少包含 RPM、TPM 和 RPD。请求会分别与每个维度比较，超过任一限制都可能触发 rate limit；限流是按 project 计算，而不是按单个 API key 计算。因此，多 key 不等于多额度，同一 project 下堆 key 通常无法真正提升项目级 RPM。

维度	含义	网关处理策略
RPM	Requests Per Minute，每分钟请求数	双桶预占中的请求桶；按 project/model/tenant/priority 细分。
TPM	Tokens Per Minute，每分钟输入 token 或相关 token 预算	在转发前估算 input/max output，预占 token 桶；响应后用 actual usage 修正。
RPD	Requests Per Day，每日请求数	用于日维度准入和租户配额；临近阈值时降级、排队或转 Batch。
IPM/TPD	部分图像/特定模型的额外限制	在 QuotaCell 中以扩展 quota_dimension 支持。

7.2 QuotaCell：额度单元模型

```
QuotaCell {
  provider: "google-gemini",
  project_id: "project-prod-001",
  region: "global" | "us-central1",
  model: "gemini-2.5-flash",
  channel_type: "standard" | "priority" | "batch" | "provisioned",
  rpm_limit, tpm_limit, rpd_limit,
  rpm_used, tpm_used, rpd_used,
  health_score, latency_p95, error_rate, rate_limit_rate,
  cost_score, priority, cooldown_until
}
```

路由不再选择“某个key”，而是选择“某个 QuotaCell”。QuotaCell 将 project、模型、区域、消费模式、额度水位、健康度、成本和优先级绑定在一起。

7.3 RPM/TPM 双桶预占与提交

```
request -> normalize -> token_estimate
        -> reserve quota: 1 RPM + estimated TPM
        -> if reserved: relay to Gemini
        -> response usage: commit actual tokens
        -> error/cancel: refund reservation
        -> timeout/disconnect: finalize by policy
```

步骤	说明
预估	使用 tokenizer 或模型特定估算器估算 input tokens，并结合 max_tokens 估算最坏输出。
预占	通过 Redis Lua 原子预占 RPM 和 TPM，避免并发下本地判断失准。
提交	响应成功后使用 usage metadata 修正实际 token 消耗。
释放	请求被拒绝、失败、取消或上游未执行时释放预占。
过期	reservation 设置 TTL，防止进程异常导致额度永久占用。

7.4 Project Pool：合规授权项目池化

由于 Gemini 限流按 project 生效，优秀设计应是 Project Pool，而不是 Key Pool。多个 project 必须来自同一主体或经授权主体，并接受统一账务、审计和合规管理。

策略	说明
绑定项目池	租户可绑定一个或多个 Google project，每个 project 可绑定模型和区域。
水位调度	当 project A 的 RPM/TPM 水位高时，将新请求调度到 project B。
冷却处理	收到 429 或 Retry-After 后，该 QuotaCell 降权并进入冷却。
权限隔离	禁止跨租户使用未经授权的 project；所有调度事件写审计。
账务归属	每次调用记录 project_id、model、tenant_id、cost ledger，便于成本回收和对账。

7.5 Admission Control：入口准入与排队

网关不应把所有请求直接转发到 Gemini 后再等待 429，而应在本地判断额度、优先级和 SLA。

```
if quota_available:
    relay_now()
elif request.can_queue and queue_wait < request.deadline:
    enqueue(priority_queue)
else:
    reject_locally(429, retry_after, reason="quota_exhausted")
```

7.6 P0/P1/P2 优先级队列

队列	场景	策略
P0 interactive	在线聊天、用户前台请求、核心交易链路	低延迟优先，禁止长时间排队，必要时降级模型或切换 QuotaCell。
P1 workflow	工作流、摘要、抽取、RAG 问答	允许短暂排队和有限重试，可做模型降级。
P2 batch	批量评测、数据清洗、批量文档处理、离线 embedding	优先转 Batch API 或低优先级队列，保护 P0。

7.7 Batch Lane：非实时任务转异步批处理

对于大规模、非紧急任务，Gemini Batch API 适合用于削峰填谷。它面向异步大批量请求，目标完成时间通常以 24 小时为边界，成本通常低于标准交互 API。

任务类型	建议执行模式
用户在线对话 / stream=true	interactive，不转 Batch
后台批量摘要 / 文档预处理	batch，按 JSONL 文件提交
评测任务 / 数据清洗	batch，低优先级、可重试
超大图片批量生成	batch，根据模型支持情况和 SLA 决定
workflow deadline > 5 分钟	auto：额度紧张时可转 batch

7.8 缓存与请求合并

机制	目标	设计要点
Exact Cache	完全相同请求直接返回	key 包含 tenant、model、prompt hash、params、schema 和安全策略。
Semantic Cache	语义相似请求复用结果	仅用于 FAQ、分类、抽取等可缓存场景；必须租户隔离。
Context Cache	长上下文重复使用降低成本	对长 system prompt、文档集、代码仓库、视频上下文建立 cache mapping。
Request Coalescing	并发相同请求合并为一次上游调用	leader/follower 模式，减少热点请求 RPM 消耗。
Tool Result Cache	缓存 RAG 检索、URL 抓取、文件解析结果	降低上游模型调用前的外部依赖成本和延迟。

7.9 Model Cascade：模型分层和自动降级

层级	模型策略	场景
Tier S	Gemini Pro / 高推理模型	复杂推理、代码重构、长文档深度分析。
Tier A	Gemini Flash / 高质量实时	常规聊天、RAG、摘要、低延迟业务。
Tier B	Flash-Lite / 低成本高吞吐	分类、轻量抽取、FAQ、简单重写。
Tier C	Embedding / 安全审核 / 本地小模型	检索、缓存命中前置、风控预判、复杂度分类。

模型降级必须由租户策略控制：默认可配置 allow_degrade、no_degrade、prefer_low_cost、prefer_low_latency。对强一致输出场景不得自动降级。

7.10 额度观测指标

- 每个 project/model/region 的 RPM、TPM、RPD 使用率和剩余水位。
- 429 rate、Retry-After 分布、cooldown 次数、自动切换次数。
- P0/P1/P2 队列长度、等待时间、丢弃率、超时率。
- Batch offload ratio、cache hit rate、request coalescing saved calls。
- token 估算误差、actual usage、成本、租户公平性。

8. 高可用智能路由引擎

智能路由引擎负责在请求进入后选择最合适的模型、渠道、项目、区域和执行模式。它需要同时考虑可用额度、健康度、延迟、成本、租户策略、模型能力和业务 SLA。

8.1 路由评分模型

```
score =
  quota_headroom_score * 0.35 +
  health_score          * 0.25 +
```

```
latency_score      * 0.15 +
cost_score         * 0.10 +
affinity_score     * 0.10 +
policy_score       * 0.05
```

评分项	说明
quota_headroom_score	当前 RPM/TPM/RPD 剩余额度越高，得分越高。
health_score	根据 5xx、429、timeout、连接错误、认证错误更新。
latency_score	p95/p99 延迟越低，得分越高；可按地域和模型独立统计。
cost_score	在满足 SLA 的前提下选择更低成本通道。
affinity_score	对上下文连续请求、长连接或缓存命中的 project/channel 给予加分。
policy_score	租户绑定、模型白名单、合规区域、数据驻留等策略满足度。

8.2 熔断、降级和重试预算

场景	处理方式
401/403	立即熔断对应 key/project/channel，进入人工确认或自动刷新流程，不重试。
429	遵守 Retry-After；同 cell 冷却；允许切换其他 quota cell；不盲目重试。
5xx/timeout	受 retry budget 限制，可跨 cell 重试一次；非幂等任务默认不自动重试。
延迟飙升	降低权重，P0 请求切换低延迟通道，P2 请求延后。
上游不可用	触发模型降级、备用供应商或本地缓存兜底，按租户策略执行。

8.3 多节点一致性

- RPM/TPM/RPD 限流、QuotaReservation、RetryBudget、ChannelHealth 和 MultiKeyPollingIndex 统一存 Redis。
- 所有关键扣减通过 Lua 脚本原子执行，避免多节点重复放行。
- Redis 故障时按策略 fail-closed 或 fail-open：金融模式下敏感接口默认 fail-closed，普通低风险流量可小窗口 fail-open。
- 通道健康状态支持短 TTL，避免错误状态长期污染路由。

9. 金融级安全与合规治理

金融级安全不只是在入口加鉴权，而是贯穿身份、授权、请求校验、密钥、审计、账本、部署、供应链和运营。

9.1 安全能力矩阵

安全域	目标能力	核心模块
身份认证	API key、JWT/JWKS、mTLS、HMAC、DPoP、MFA、ephemeral token	ClientCredential、AuthValidator、MFAService
授权控制	RBAC/ABAC、RoutePolicy、scope、租户、模型和分组控制	PolicyEnforcer、RouteSecurityPolicy
请求保护	schema validation、body size、file type、URL allowlist、SSRF 防护	SchemaValidator、RequestGuard
密钥保护	KMS/Vault、Envelope Encryption、版本、轮换、访问审计	SecretProvider、SecretMetadata
审计留痕	管理操作、密钥访问、策略变更、账务事件不可篡改记录	AuditEvent、HashChain、SIEM Sink
供应链安全	SAST、DAST、secret scan、SBOM、镜像签名、依赖漏洞门禁	CI/CD Security Gate
部署安全	TLS、mTLS、WAF、IP allowlist、只读容器、最小权限	Ingress、K8s NetworkPolicy、Vault Agent

9.2 Financial Security Mode

新增 NEW_API_SECURITY_MODE=financial。开启后系统必须执行更严格的启动检查和运行时策略。

检查项	金融模式要求
SESSION_SECRET	必须设置，长度和随机性符合要求；不允许默认 UUID。
CRYPTO_SECRET / KMS	必须设置 KMS/Vault 或强随机本地密钥；支持密钥版本。
AUDIT_HMAC_KEY	必须设置，用于 AuditEvent Hash Chain。
默认 root	禁止创建固定密码；首次启动生成一次性 setup token。
管理后台	必须启用 MFA 或至少 root 高风险操作 Step-up MFA。
WebSocket	必须配置 Origin allowlist 或仅允许非浏览器 mTLS/HMAC 客户端。
日志脱敏	Authorization、Cookie、key、password、prompt 默认脱敏。

9.3 密钥生命周期

```
plaintext upstream key
-> generate data key from KMS/Vault
-> encrypt plaintext with data key
-> store ciphertext + key_version + kms_key_id
-> decrypt only inside request scope
-> audit every decrypt-for-use event
-> rotate by version, re-encrypt asynchronously
```

10. 鉴权与权限控制体系

10.1 SecurityContext

```
type SecurityContext struct {
    RequestID    string
    TraceID      string
    TenantID     string
    UserID       int
    TokenID      int
    ClientID     string
    ClientCertFP string
    AuthMethod   string // api_key, jwt, mtls, hmac, dpop, session
    Roles        []string
    Scopes       []string
    SourceIP     string
    UserAgent    string
    RiskLevel    string
    RouteID      string
    Model        string
    Group        string
}
```

10.2 RouteSecurityPolicy

字段	说明
route_id	例如 POST /api/channel/:id/key 或 POST /v1/chat/completions。
required_auth_methods	api_key、jwt、mtls、hmac、session，可多选。
required_roles/scopes	角色和 scope 必须同时满足。
require_mfa	敏感接口必须 step-up MFA。
require_approval	密钥导出、支付配置、策略变更等可要求双人审批。
ip_allowlist	管理接口和企业客户可绑定 IP/CIDR。

deny_query_token	高风险路由禁止 query string 传 token。
audit_level	none、basic、full、redacted_full。

10.3 敏感接口分级

等级	接口类型	控制措施
L1	普通模型调用	API key/JWT + quota + rate limit + 基础日志。
L2	用户资料、普通 token 管理、余额查询	session/API token + 用户权限 + 审计。
L3	渠道、模型、支付、OAuth provider、订阅计划	Admin/Root + MFA + IP allowlist + 完整审计。
L4	查看/导出上游 key、批量 token key、系统安全策略	Root + MFA + 双人审批 + 临时授权 + 不可篡改审计。

11. 账本化计费、配额与对账

当前预扣和退款逻辑需要升级为账本化模型。金融级系统中，余额不是事实源；BillingLedger 才是事实源。每个扣费、退款、调整和违规费用都必须有独立事件。

11.1 BillingLedger 事件模型

事件	触发时机	说明
preauth	请求通过准入后、调用上游前	预授权/预扣，锁定预算但不最终入账。
capture	上游成功返回后	按 actual usage 入账，多退少补。
refund	上游未执行、失败或按策略退款	释放 preauth 或反向冲正。
adjustment	人工调整、补偿、纠错	必须审批并完整审计。
violation_fee	命中违规策略或滥用成本	按平台政策执行，需可追踪。

```
BillingLedger {
  ledger_no, request_id, idempotency_key,
  tenant_id, user_id, token_id, channel_id, quota_cell_id,
  model, event_type, amount, currency,
  prompt_tokens, completion_tokens, cache_tokens,
  status, prev_hash, event_hash, created_at
}
```

11.2 对账机制

- 请求日志、上游 usage、BillingLedger、用户余额四方对账。
- 每天生成租户账单、渠道成本、模型成本和异常差错报告。
- 发现余额不一致、capture 缺失、refund 未完成、重复 idempotency key 时进入 reconciliation_errors。
- 所有人工调整必须有审批单、操作人、原因、前后差异、审计 hash。

12. 全链路可观测平台

面向 AI 网关的可观测不应只看 QPS 和 HTTP 状态码，还必须看模型、渠道、额度、成本、队列、缓存、账本和上游错误。

12.1 Dashboard 设计

看板	关键指标
总览看板	QPS、成功率、p50/p95/p99、错误率、429 rate、活跃租户、成本、token。
Gemini 额度看板	project/model/region 维度 RPM/TPM/RPD 水位、cooldown、Retry-After、切换次数。
路由健康看板	channel health score、熔断状态、自动恢复、降级、重试预

	算。
队列看板	P0/P1/P2 队列长度、等待时间、超时、丢弃、batch offload。
缓存看板	exact/semantic/context/tool cache hit rate、saved calls、saved tokens、缓存成本。
计费看板	preauth/capture/refund 数量、金额、差错、租户账单、渠道成本。
安全审计看板	敏感操作、失败登录、MFA、密钥访问、策略变更、异常 IP。

12.2 告警规则

告警	条件示例	处理建议
Gemini 429 升高	5 分钟内某 QuotaCell 429 rate > 2%	降权、cooldown、切换 project、检查额度水位。
P0 队列等待过长	p95_queue_wait > 2s	启用备用通道、模型降级、限流 P2。
计费对账异常	ledger 汇总与用户余额不一致	冻结相关调整，进入人工复核。
密钥访问异常	短时间多次查看/导出 key	触发安全告警和审批复核。
认证失败激增	某 IP/tenant 401/403 激增	IP 限制、WAF、Credential rotation。
Redis 降级	Redis unavailable > 30s	金融模式敏感接口 fail-closed；普通流量进入本地小窗口。

13. 数据模型与源码改造清单

13.1 新增核心数据模型

模型	作用	关键字段
ClientCredential	企业客户端身份	client_id, tenant_id, auth_method, jwks_url, cert_fingerprint, scopes, status
RouteSecurityPolicy	路由级安全策略	route_id, auth_methods, roles, scopes, require_mfa, approval, audit_level
APIEndpoint	API 资产清单	method, path, category, owner, risk_level, schema_id, deprecated
RateLimitPolicy	限流策略	scope, algorithm, limit, window, burst, cost_expression, mode
QuotaCell	上游额度单元	provider, project_id, model, region, rpm/tpm/rpd, health_score
QuotaReservation	额度预占记录	reservation_id, rpm, estimated_tpm, actual_tpm, status, expires_at
BillingLedger	账本事件	ledger_no, request_id, event_type, amount, tokens, prev_hash, event_hash
AuditEvent	不可篡改审计	actor, action, resource, result, payload_hash, prev_hash, event_hash
SecretMetadata	密钥元数据	secret_ref, kms_key_id, key_version, algorithm, rotated_at, last_accessed_at
ChannelHealth	渠道健康状态	channel_id, quota_cell_id, error_rate, latency_p95, breaker_state, cooldown_until

13.2 推荐新增目录结构

```
pkg/  
  auth/  
  security/  
  ratelimit/  
  quota/  
  ledger/  
  audit/  
  secrets/  
  schema/  
  routerx/  
    # jwt, jwks, mtls, dpop, hmac  
    # context, policy, redactor, canonical  
    # redis token bucket, lua, local fallback  
    # quota cell, reservation, scheduler  
    # preauth, capture, refund, reconcile  
    # event, hashchain, SIEM sink  
    # local, kms, vault provider  
    # OpenAPI / JSON Schema registry  
    # quota-aware router, circuit breaker
```

```
middleware/  
  security_context.go  
  client_auth.go  
  policy_enforcer.go  
  schema_validation.go  
  adaptive_rate_limit.go  
  audit.go  
  ws_origin.go  
model/  
  client_credential.go  
  route_security_policy.go  
  api_endpoint.go  
  rate_limit_policy.go  
  quota_cell.go  
  quota_reservation.go  
  billing_ledger.go  
  audit_event.go  
  secret_metadata.go
```

13.3 关键源码改造点

PR	范围	关键文件
PR-1 Financial Security Mode	强制生产密钥、删除默认 root/123456、setup token	common/env.go, model/main.go, controller/setup.go
PR-2 SecurityContext + Audit Skeleton	统一上下文、trace、基础审计	middleware/security_context.go, model/audit_event.go
PR-3 Route Policy Enforcer	路由策略、MFA、IP allowlist、scope	middleware/policy_enforcer.go, model/route_security_policy.go
PR-4 JWT/JWKS/mTLS/HMAC	企业认证方式	pkg/auth/*, middleware/client_auth.go
PR-5 QuotaCell + 双桶限流	Gemini 项目池化、RPM/TPM 预占	pkg/quota/*, pkg/ratelimit/*
PR-6 Ledger Billing	预扣/提交/退款账本化	pkg/ledger/*, model/billing_ledger.go, controller/relay.go
PR-7 Router & Circuit Breaker	健康评分、熔断、RetryBudget	pkg/routerx/*, service/channel_health.go
PR-8 Observability	指标、trace、dashboard、告警	pkg/metrics, logger, controller/observability.go

14. 接口与 SDK 接入规范

14.1 业务调用接口

接口	用途	备注
POST /v1/chat/completions	统一聊天接口	OpenAI-compatible 主接口，支持 Gemini/Claude/OpenAI-compatible 路由。
POST /v1/responses	Responses 风格接口	适配更复杂工具调用和多模态响应。
POST /v1/embeddings	Embedding 接口	支持缓存和批量优化。
POST /v1/images/generations	图像生成接口	支持图像模型限流维度 IPM。
POST /v1/batches	统一批处理提交	内部可映射到 Gemini Batch API 或其他上游 Batch。
GET /v1/batches/{id}	批处理状态查询	返回 queued/running/succeeded/failed/expired。
GET /v1/models	模型列表	按租户权限返回可用模型和降级策略。

14.2 管理接口

接口域	能力
/api/security/policies	RoutePolicy、限流策略、审批策略和敏感接口分级管理。
/api/credentials/clients	ClientCredential、JWKS、证书指纹和 scope 管理。

/api/quota/cells	QuotaCell、Project Pool、模型额度和水位管理。
/api/audit/events	审计事件查询、导出和 hash 验证。
/api/ledger/reconciliation	对账任务、差错处理和账单导出。
/api/observability/*	指标、SLO、队列、渠道健康和告警查询。

14.3 SDK 设计要求

- 自动注入 X-Request-ID、Idempotency-Key 和 trace headers。
- 遵守 Retry-After，避免客户端重试风暴。
- 支持模型自动降级策略显式声明。
- 支持 batch/async 提交和状态轮询。
- 支持错误码分类：认证失败、权限失败、额度不足、上游限流、临时故障、不可重试错误。

15. 部署架构与运维方案

Internet / Enterprise Network

- > CDN / WAF / DDoS / Bot Protection
- > Ingress / Envoy / Nginx: TLS termination, mTLS, body limit
- > new-api data plane pods x N: stateless runtime
- > Redis Cluster: quota, rate limit, replay nonce, health state
- > PostgreSQL HA: config, ledger, audit index, business data
- > Object Storage / SIEM: immutable audit archive, reports
- > KMS / Vault: upstream secrets, signing keys, encryption keys

15.1 生产部署要求

类别	要求
网络	仅暴露网关入口；DB/Redis/Vault 内网访问；管理后台建议 IP allowlist 或独立域名。
TLS	外部 TLS 1.2+；服务间建议 mTLS；禁止 InsecureSkipVerify。
容器	只读 root filesystem、非 root 用户、资源限制、镜像签名、SBOM。
数据库	PostgreSQL HA、PITR、定期备份、恢复演练；日志库可独立。
Redis	Redis Cluster/Sentinel；AOF/RDB 策略按业务决定；关键限流需高可用。
密钥	Vault/KMS 注入，禁止长期明文写入 .env；支持轮换。
日志	结构化 JSON、敏感脱敏、审计单独归档，支持 SIEM。
发布	蓝绿/金丝雀、数据库迁移回滚方案、配置灰度。

15.2 灾备指标

场景	目标	策略
单 pod 故障	无感恢复	K8s readiness/liveness + 多副本。
单 AZ 故障	分钟级恢复	多 AZ 部署，数据库跨 AZ HA。
Redis 故障	敏感 fail-closed，普通小窗口降级	本地限流兜底 + 告警 + 快速切换。
主库故障	RTO 按业务定义，RPO 接近 0	同步复制/PITR/演练。
上游 Gemini 区域/项目限流	P0 持续可用	Project Pool + Model Cascade + Batch offload。

16. 分阶段开发路线图

阶段	周期	目标	主要交付
P0 安全基线	1-2 周	消除高危默认行为，建立金融模式	Financial Security Mode、setup token、Origin 白名单、日志脱敏、生产密钥门禁
P1 身份与授权	2-4 周	构建企业认证和路由策略	SecurityContext、ClientCredential、JWT/JWKS、mTLS/HMAC、RoutePolicy、MFA
P2 额度与路由	3-5 周	提升 Gemini 官方直连有效吞吐	QuotaCell、Project Pool、RPM/TPM 双桶、优先级队列、Batch Lane、熔断
P3 计费与审计	4-6 周	账本化计费和不可篡改审计	BillingLedger、AuditEvent、HashChain、Reconciliation、SIEM sink
P4 API 治理	3-5 周	补齐资产清单和请求校验	API inventory、OpenAPI/JSON Schema、unknown endpoint block、SDK 规范
P5 生产化与合规	4-8 周	通过安全测试、压测和灾备演练	SAST/DAST、SBOM、镜像签名、压测、渗透、灾备报告、运维手册

16.1 里程碑验收

里程碑	验收标准
M1 安全启动	financial 模式下无必填密钥无法启动；无默认 root/123456；setup token 一次性有效。
M2 强认证	有效 JWT/mTLS/HMAC 可访问授权路由；无效签名、过期、aud 不匹配全部拒绝。
M3 路由与额度	RPM/TPM 双桶在多节点压测下不超发；429 自动降权和 cooldown 生效。
M4 账本	preauth/capture/refund 完整闭环；重复 Idempotency-Key 不重复扣费。
M5 可观测	trace_id 可关联请求日志、上游调用、ledger、audit；dashboard 展示额度水位和队列。
M6 合规上线	通过 OWASP API Top 10 测试、渗透测试、压测、备份恢复演练。

17. 测试、验收与上线门禁

17.1 测试矩阵

类型	覆盖内容
单元测试	Token 解析、JWT/JWKS、HMAC、RoutePolicy、Quota 预占、Ledger 状态机。
集成测试	OpenAI-compatible、Gemini 原生、Batch、Streaming、失败重试、降级。
并发测试	多节点 RPM/TPM 限流、QuotaReservation TTL、Redis 故障、本地兜底。
安全测试	BOLA、Broken Auth、资源消耗、函数级授权、SSRF、配置错误、资产清单。
计费测试	成功、失败、断连、上游 429、超时、重复请求、人工调整和对账。
可观测测试	trace 串联、指标准确性、日志脱敏、SIEM 输出、告警触发。
灾备测试	DB failover、Redis failover、上游不可用、AZ 故障、回滚演练。

17.2 上线门禁

- 高危漏洞为 0；中危漏洞有修复计划和风险接受记录。
- 所有敏感接口均有 RouteSecurityPolicy 和审计事件。
- 所有密钥字段在 DB 中为密文，密钥读取有审计。
- Redis/DB 故障演练通过，明确 fail-open/fail-closed 策略。
- 压测下 P0 队列 p95 等待、429 rate、错误率满足 SLO。
- 账本与余额对账一致，重复请求不重复扣费。
- 管理后台启用 MFA，Root 操作有审批和审计。
- 文档、SDK、错误码、运维手册、回滚手册齐全。

18. 风险清单与治理措施

风险	影响	治理措施
过度追求吞吐导致违规	账号/项目受限，业务中断	明确合规口径；仅使用授权 project；限流与审计保留证据。
缓存污染或越权复用	数据泄露或错误响应	缓存 key 强制包含 tenant、policy、model、schema；敏感请求默认不缓存。
模型自动降级影响质量	业务结果不可接受	降级必须由租户策略显式允许；关键任务 no_degrade。
账本改造影响现有计费	迁移期间账务不一致	双写观察期、回滚方案、日终对账、灰度租户。
Redis 单点影响限流	超发或误拒	Redis HA；敏感 fail-closed；普通流量本地小窗口。
管理接口审批降低效率	运维体验下降	仅 L4 或高风险 L3 强审批；普通操作保留快速通道。
Schema 过严影响兼容	客户端升级成本高	shadow mode 观察、灰度阻断、兼容窗口和错误提示。

19. 交付物清单

类别	交付物
架构设计	总体架构图、数据面/控制面/可观测面/审计账本面设计、部署拓扑。
源码设计	模块目录、数据模型、关键中间件、PR 拆分和迁移策略。
安全设计	认证、授权、RoutePolicy、MFA、审批、密钥、审计、供应链安全方案。
Gemini 直连方案	QuotaCell、Project Pool、双桶限流、队列、Batch、缓存、熔断、观测。
计费方案	BillingLedger、幂等、preauth/capture/refund、对账和差错处理。
运维方案	部署、HA、备份、灾备、告警、SLO、容量规划和故障手册。
接入方案	统一 API、SDK、请求头、错误码、Batch/Async 接口和示例。
测试验收	测试矩阵、上线门禁、压测和安全测试报告模板。

20. 参考资料

资料	链接
Google AI for Developers - Gemini API Rate limits	https://ai.google.dev/gemini-api/docs/rate-limits
Google AI for Developers - Gemini Batch API	https://ai.google.dev/gemini-api/docs/batch-api
Google AI for Developers - Gemini Context caching	https://ai.google.dev/gemini-api/docs/caching
Google Cloud - Gemini Enterprise Agent Platform quotas and	https://docs.cloud.google.com/gemini-enterprise-

system limits	agent-platform/models/quotas
OpenID Foundation - FAPI 2.0 Security Profile	https://openid.net/specs/fapi-security-profile-2_0.html
NIST SP 800-207 - Zero Trust Architecture	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf
OWASP API Security Top 10 - 2023	https://owasp.org/API-Security/editions/2023/en/0x11-t10/

附注：具体限流数值、模型列表、Batch 支持范围和价格会随官方平台变化而变化，生产实现应从官方 API/控制台定期同步并以租户配置为准。